

nexpo — Release 3.0: Release Notes

AI Financial Copilot

Platform: Vercel AI SDK v7 + OpenRouter (free models), integrated into the existing Next.js + Supabase stack.

1. Receipt OCR (AI-powered extraction)

- Receipts scanned via a vision model using structured-output generation (`generateObject` + zod schema).
- Extracts: amount, date, merchant/title, currency, **transaction type (DEBIT/CREDIT)** and **payment type (CARD/CASH/UPI/etc.)**.
- Category and payment method auto-populate from the user's own lists (matched by name).
- Supports JPG/PNG/WEBP, 10 MB max; graceful errors for bad files (415), oversized (413), and AI-disabled (503).
- Per-user rate limit: 50 scans/day.

2. Financial Copilot (streaming AI chat assistant)

- New "Assistant" page in the customer portal — real-time streaming chat.
- Read-only, user-scoped **tools** the AI can call against live data:
 - `readTransactions` — filter by date/type/category.
 - `monthlySummary` — spend/income by category per month (auto-corrects to real months).
 - `forecastCashflow` — projected income/spend over coming months.
 - `getSavingsOpportunities` — detected recurring subscriptions + budget-overrun candidates.
- Rejects invented numbers — all figures come from deterministic aggregates of the user's own data.
- Understands relative dates ("last month", "this month") via an injected current date.
- Markdown rendering (tables, lists) in answers; tool activity shown as compact chips.
- Detect-and-cancel on disconnect; bounded tool loop; per-user limit: 20 messages/day.

3. Proactive Insights (dashboard)

- AI-generated financial insight cards on the customer dashboard — no prompting needed.

- Compares current vs. previous month, highlights category spikes/dips, recurring subscriptions, and overrun estimates (max 6, ranked by importance).
- Cached per-user per-day (no repeat billing); degrades gracefully when AI is disabled (cards hide, no errors).
- Per-user limit: 5 refreshes/day.

4. Hardening, Reliability & Security

- **Model fallback chain** — auto-retries the next model in the list on 429/5xx, so a transient provider failure doesn't fail a turn.
 - **Consistent error mapping** — provider errors surfaced with real messages (e.g., the actual OpenRouter quota text); routes return proper 400/415/413/422/429/503.
 - **Rate limiting** on every AI route (OCR 50/day, chat 20/day, insights 5/day).
 - **Usage audit table (`AiUsage`)** — every call logs feature, model, tokens, latency, status — PII-free, powers cost/usage tracking.
 - **Security review** — keys server-only, user data scoped per authenticated user, prompt-injection guard on the copilot, no PII in audit logs.
 - **Test suite added** — 35 tests (OCR validation + error mapping, aggregate correctness, rate-limit behavior, fallback logic, unconfigured-503). `tsc` , ESLint, and production build all clean.
-

Caveat

M3 (proactive insights) content generation is code-complete but **not yet live-verified** — temporarily waiting on the OpenRouter free-tier daily quota. Endpoint, auth, caching, and rate limits are verified.